Backend, RLS tests and membership reference pack

Files: backend_routes.ts (Express + Zod + Supabase caller-scoped read routes and mutation adapters), 004_note_command.sql (working reference note RPC), rls_reference_tests.sql (pgTAP fixtures/assertions), proposed_membership_catalog.json (DRAFT), frontend_component_specs.md.

Dependencies: express, @supabase/supabase-js, zod, TypeScript; matching Express typings. Mount makeSemesterRouter at /api/v1. Install bounded express.json({limit:'128kb'}) and rate limits before router; handle JSON parse/size errors at app level. Bearer-only auth shown; cookie deployments need appropriate CSRF protection. Node modern global crypto required. Router uses getUser(token) and user-scoped clients, never service_role. Do not expose sx_private. Configure sx/sx_personal exposure separately. No provider secrets in browsers.

Code not compiled or executed. No repository modification or remote state change. Read endpoints and note RPC have concrete implementations. Checkout/change/institution request/membership routes require Commerce adapter implementations; absent adapter returns 501. Do not pretend those routes process money. Adapters must perform object-level authorization, durable transactions/idempotency, approved catalog lookup, price/tax/currency resolution, signed terms and tokenized rails. Existing sx commercial subscription schema does NOT model self-serve personal subscriptions completely; add personal billing-owner/sponsor/usage models before wiring paid handlers. Raw rail callbacks and signature verification are not part of this route file.

Note RPC assumes auth session, table owner trust, no FORCE RLS, prior sx_personal.notes. Direct table writes stay denied. Command bypass is narrowly checked. Map SQL 22023 and other domain errors more finely for production. Global HTTP exception mapping currently treats unknown adapter errors as 500; adapters should expose a reviewed typed error protocol, not leak messages.

RLS tests run ONLY on a disposable Supabase local database after sx consolidated schema/access/permission migrations and note RPC. Install pgTAP and run supabase test db (place SQL in its test directory) or pg_prove against local DB. Fixtures use deterministic UUIDs and example.invalid emails; transaction rolls back everything. Tests are written, not executed. Test inputs grant actors narrowly and test under authenticated/anon database roles with request.jwt claims. Fixture writes run as trusted migration role. Structural checks cover all tables; behavioral tests cover representative education/doc/billing/owner access, not exhaustive 71-table/69-screen permutations. Extend with financial command races, provider idempotency, section-within-tenant negatives, storage, restrictive grant changes, API and UI tests. Never run fixture scripts against production.

Pricing: proposed USD list amounts before tax, not approved/published prices or a profitability finding. Free 0, Plus 8.99/month or 69/year, Pro 17.99/month or 149/year. Institutional 18/enrolled student/year, 30000 annual minimum. Plus and institutional figures carry forward earlier planning; Pro is a new proposal. Quota credits are not raw tokens and require

model/action budget guardrails. Annual personal payment grants a year of service; AI allowance resets monthly, not 12x upfront. Institution budget resets under contract, pooled per tenant with approval. Overages default off until explicitly approved. Implementation/services/support pricing is separate negotiated scope; institutional features activated module-by-module after proof, not merely payment.

Cancellation: stops next renewal, normally preserves current paid period; downgrades normally at period end; upgrades/cadence change must disclose exact effective date and proration and require payment confirmation where policy needs it. Do not destroy over-quota retained files; enforce new uploads under retention/grace policy. Role access independent from membership tier. Sponsored and personal allowances remain separate; institutional budget loss never deletes education records. No unapproved lifetime plan in this three-tier design.